

工程领域重大专题研讨

能源互联网边缘安全区域自治技术研究与应用

(清华大学自动化系, 崔崑)

摘要： 本文简述能源互联网发展的重要意义和技术依赖，以及信息安全建设对能源互联网发展的必要性。随后通过分析信息安全现状与其产生的原因，提出边缘安全区域自治，云边协同管理安全的建设思路以及相关的模块设计，并探讨了其中关键技术的研究思路；最后介绍了本研究预期达到的效果。

关键字： 能源互联网、零信任、边缘计算、软件定义边界

1. 选题背景

1.1. 能源互联网发展

美国社会学家杰里米·里夫金在其著作《第三次工业革命》中认为第三次工业革命将是一场能源革命，可再生能源与互联网的结合，正是这一场革命的重要推动力。随着经济的快速发展，我国已经成为世界上最大的能源生产国、消费国以及碳排放国。随着国家经济实力的增强，人民群众的生活改善，环境问题成为我国人民生活中越来越重视的话题。2010年以来，雾霾、饮用水污染、土壤毒化等问题屡屡登上各类媒体的头条，严重地影响了国人的健康和日常生产生活等活动。尽管在不断调整能源结构，我国的能源消费结构仍然是化石能源为主，清洁能源的占比较低。这样的能源消费结构称为了环境问题屡现的主要原因之一。

2015年9月26日，习近平总书记在联合国发展峰会上倡议探讨构建全球能源互联网，推动以清洁和绿色方式满足全球电力需求。中国电力企业联合会在一年以后出台的企业标准 T/CEC 101.1-2016 中，对能源互联网定义如下：以电能为核心，集成冷、热、燃气等能源，综合利用互联网等技术，深度融合能源系统与信息通信系统，协调多能源的生产、传输、分配、存储、转换、消费及交易，具有高效、清洁、低碳、安全特征的开放式能源互联网络[1]。电能替代和清洁替代成为能源互联网的两项关键目标。电能替代是以

电能替代冷、热、燃气、燃油等其它能源，目的是降低分布式的排放比例，减少散烧，以电动汽车、电能采暖、电能锅炉等为代表的改变是电能替代的主要体现。清洁替代是以清洁能源代替化石能源生产电能，包括水、风、阳光等，目的是进一步降低化石燃料在能源结构中的比例，降低化石燃料产生的排放。

1.2. 能源互联网技术

由于我国清洁能源和需求的逆向分布，能源互联网建设对电网运行带来了巨大挑战。特高压输电技术、清洁能源技术以及智能电网技术等亟需进一步发展[2]。这些技术高度依赖电网信息化、数字化和智能化的程度。目前我国的电网在输变电的自动化发展相对成熟，但是营销和配电网的自动化程度还较低，距离数字化、智能化还有一定的差距。

目前，我国的两大电网公司（国家电网和南方电网）都提出了以数字化转型为核心的智能电网建设的战略目标。电力物联网建设成为实现数字化转型的关键要素。随着电力物联网建设的进行，两大电网公司都初步具备了海量智能物联网设备接入的能力，为能源互联网的建设、发展打下了良好的基础。

1.3. 能源互联网的安全风险

由于物联网设备的计算能力有限，且具有海量、异构、分散、无人值守、应用场景庞杂、安全防护能力差等特点，如何保护电力物联网络成为一个庞大的安全难题。另一方面，当今世界，以能源基础设施为目标的攻击越来越多。2015年乌克兰电网遭受黑客攻击，导致了部分地区长达6个小时的停电。2016年以色列的电力系统遭受了大规模的网络攻击，导致电力公司不得不下线了大量的计算机设备。2019年委内瑞拉数次影响巨大的全国性的大停电事件也源于黑客攻击。2020年，美国、欧洲、巴西、印度、日本等国家的电力系统都爆遭受黑客攻击的事件，这些事件对其电力供应产生了不同程度的影响。

因此，我国在规划、建设能源互联网的同时，信息安全建设必须同步进行。

1.4. 本章小节

本章内容简述了我国发展能源互联网的重要意义，同时阐述了智能电网对于能源互联网建设的必要性和紧迫性，最后通过列举近年来的电力系统的安全事件强调了能源互联网的信息安全风险。

2. 安全现状及问题分析

2.1. 安全现状

我国的电网企业一直以“安全分区、网络专用、横向隔离、纵向认证”的“十六字方针”作为信息安全的基本指导[3]。“十六字方针”在电网信息化建设中，有效的保障了电网的信息安全。但是，随着能源互联网的建设不断深入，“十六字方针”以边界防护为主的理念，无法适应与高度数字化、智能化，且具有泛在连接，开放共享等特性的能源互联网的现实需求；一定程度上甚至制约了能源互联网的建设与发展。因此，建设能源互联网须要突破“十六字方针”思考信息安全。

2.2. 安全问题分析

电力信息网络是工业信息网络在电力系统的具体体现。早期工业信息网络的安全防御体系的设计源自企业信息网络安全的设计理念：采用自上而下的设计理念，强调管理级、系统级的安全。这样的理念在传统的信息办公网络中得到了充分的发展和应用，在以边界防御为核心的工业信息网络中（包括电网系统），也取得了的成效。随着物联终端接入数量的增加，受到算力、环境、分布等因素的限制的物联终端无法应用源自数据中心的安全策略和防御手段。为了保障生产业务的连续性，大量物联终端便被暴露在安全防护体系之外；出现了“管而不控”，甚至“不管不控”的现象。终端安全事件一旦发生，管理人员难以及时发现。APT（Advanced Persistent Threat，高级持续威胁）类型的攻击的前期入侵通常利用这种疏漏，成功地在物联终端上侵入，并成为下一步攻击的桥头堡。自上而下的设计理念，容易产生云端及数据中心重兵把守，边缘及终端防御缺失的现象，对系统的整体安全带来了巨大的风险。

为了应对自上而下的设计理念的局限性，工业信息网络中诞生了自下而上的安全设计理念。自下而上的理念以单个设备为基础，强调设备个体的安全。通过对设备自身安全能力的增强，实现“细胞级”的自身安全免疫能力。这一设计理念，强化了网络设备的个体安全，在不具备系统级防护能力的在工业信息网络中，产生了一定的效果。但是在具有海量的异构设备，且安全管理要求较高的场景中，以个体为基础的安全策略暴露出难以统一管理的问题；同时，由于安全事件由个体自身的安全能力处置，安全管理者无从知晓这些安全事件，因此自下而上的设计理念通常不具备整套系统的安全闭环能力。

综上所述，发展能源互联网，需要针对能源互联网“云、管、边、端”的架构，充分考虑能源互联网的特性以及生产、传输、调度、消费等各方面的需求及现状，找到一种新的设计理念，能够保证“云、管、边、端”中整体与个体安全，同时具备整体安全闭环的管控能力。

2.3. 本章小节

本章简单介绍了我国电网公司目前的安全建设方针，并分析了工业信息网络中常见的安全架构设计的优势与不足，最后提出针对能源互联网“云、管、边、端”的架构，需要一种新的安全设计理念。

3. 需要研究的内容

3.1. 边缘安全区域自治，云边协同管理安全

能源互联网的建设中，电力物联网的“云、管、边、端”架构已经为各方所认可。以边缘计算节点为中心，将中心与相关联设备、资源等定义为边缘区域（边缘侧），形成以边缘安全区域自治，云边协同管理安全的安全治理架构（图 1）：即保证了边缘区域的安全，又兼顾了云端统一管理的需求。

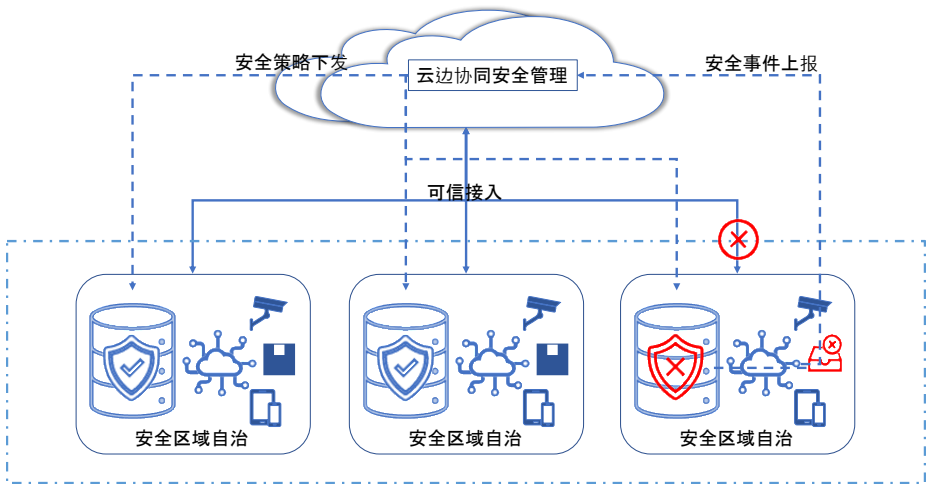


图 1. 边缘安全区域自治，云边协同管理安全的安全治理架构

由于边缘区域部署位置通常不具备较强的物理安全防护，且相互连接协议多样，访问请求主体复杂，粗粒度的授权与网络隔离很难为边缘区域各类资源提供有效的安全保护。

零信任网络架构（Zero Trust Network Architecture, ZTNA）具备软件定义边界（Software Defined Perimeter, SDP）和网络微隔离（Micro-segmentation）的能力。零信任的核心是从不信任，总是验证，只做最小授权（least privilege），并对行为持续监控[4]。这使得 ZTNA 能够适应边缘侧的应用场景，有效的做好安全防护。SDP 将安全的控制平面与数据平面分离，使得边缘安全区域自治成为可能。将对行为的持续监控汇总到云端，再进行计算反馈，可以达到云边协同安全管理的目的。因此，ZTNA 可以作为建设安全边缘区域自治的基本安全架构。本研究在 ZTNA 的框架下，以实现边缘安全区域自治，云边协同管理安全的基础功能为目标，将聚焦在边缘计算节点本体安全、边缘网络安全、云端交互安全及安全持续监控与反馈四方面（图 2）。

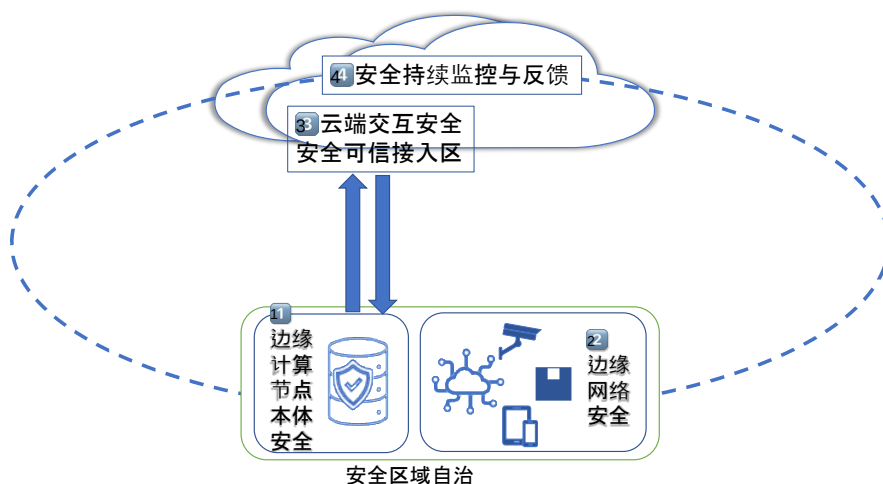


图 2. 边缘安全区域自治的主要模块

3.2. 技术创新点

本研究预期有两项创新之处：其一是针对电力物联网的“云、管、边、端”架构提出了以边缘计算为中心的边缘安全区域自治的设计方法；其二是提出了云边协同的安全闭环。

3.2.1. 以边缘计算节点为中心的边缘安全区域自治的设计方法

工业信息网络中,常见的安全设计方法是自上而下的梳理设计;为了应对海量物联终端的场景,又提出了自下而上的设计思路。这两种设计方法针对电力物联网的“云、管、边、端”架构都具有一定的局限性。本研究提出以边缘计算节点为中心的边缘安全区域自

治的设计方法，能够克服上述两种设计思路的局限性，以边缘安全区域自治为基本要求，兼顾边缘及个体安全，和云端统一管控的需求。

3.2.2. 云边协同的安全闭环

边缘安全区域自治能够实现本区域的安全闭环。在“云、管、边、端”架构中，这样的安全闭环无法与其它区域及云端的安全态势共享。将 ZTNA 对安全持续监控和反馈的要求，扩大到整套系统，将监控和反馈的工作交予云端运行，能够实现云边协同的安全闭环。云端服务通常具有比边缘节点更强大的算力，可以结合威胁情报和其它边缘环境上报的安全事件进行综合分析，及时发现潜在的各类攻击，并制定出应对策略下发到相关的边缘区域。

3.3. 具体研究内容：

3.3.1. 边缘计算节点本体安全

本体安全是零信任的基础。在电力物联网中，边缘计算节点通常作为北向接入云端主站，南向连接感知终端的边缘计算区域关键设备。作为边缘计算区域的核心和最具算力的设备，一旦被攻击者渗透，不仅有可能影响边缘区域的其他设备及数据的安全，更有可能利用边缘计算节点的算力对云端主站发起攻击，从而影响整个电网的健康运行。

维护边缘计算节点本体安全，要求边缘计算节点具有对自身安全状态持续监控和检测的能力，并能够依据安全策略对安全事件及时响应和处置。由于南向连接的智能感知设备通常计算能力较弱，要求边缘计算节点同时具备对这些设备的连接状态、上报数据、运行行为等特征进行安全持续监控的能力，实现针对下联感知终端安全防护。同时，边缘计算节点应具备依据云端策略对持续对自身安全加固的能力（表 1）。

目的	研究对象	研究目标
本体安全	运行环境信息	启动及运行环境监控，建立安全基线、异常发现及响应
	运行进程行为	进程行为监控，建立安全基线、异常发现及响应
	云端策略执行	依据云端策略持续进行自身安全加固，更新安全基线
南向安全	下联设备状态	下联设备连接状态及运行状态监控
	下联数据传输	下联设备传输数据监控及保护

表 1. 本体安全研究对象及目标

3.3.2. 边缘网络安全

依据 ZTNA 理论，边缘网络应对所有接入设备微隔离，仅有经过可信认证的连接及访问请求才能够被许可，同时按照访问目的赋予最小授权。由于边缘网络连接设备及方式多样，各类设备厂商出于设备运维等需求，也有通过不同形式和协议的接入需求，造成边缘区域网络安全形势复杂。传统安全体系仅仅能对通过以太网接入的访问请求进行准入控制，访问控制权限颗粒较粗。一旦授权，对该接入设备的行为便无从管控。对于通过非以太网接入的场景（通常是运维人员接入）则完全无法管控。因此，需要对各种连接及访问场景进行梳理，并研究设计基于 SDP 的可信接入代理服务装置。该服务装置集成了 SDP 访问控制器和可信接入网关。客户端通过该服务装置，可以将外部接入（以太、无线、Console、UART、USB 等）操作做统一的安全管控，并对边缘网络安全态势持续监控（图 3）。由于采用软件定义边界的技术，该更具备了安全的远程运维的能力，在满足安全规范的前提下，为运维人员提供远程运维的条件。

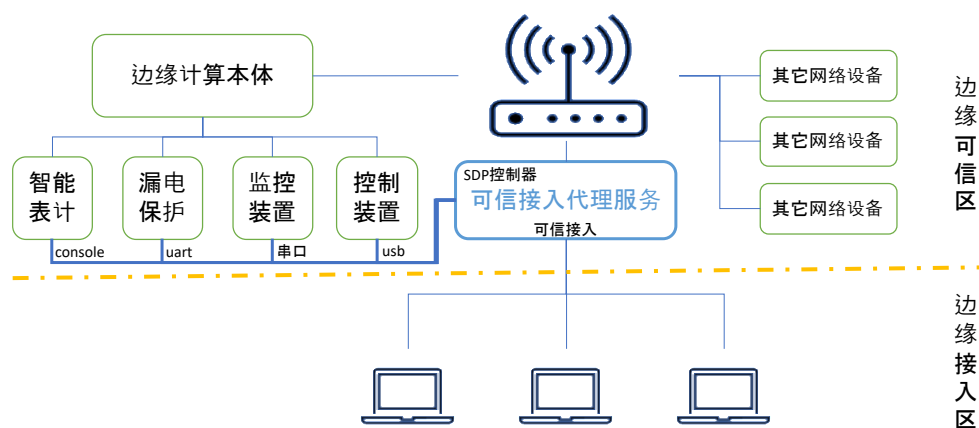


图 3. 可信接入代理服务

3.3.3. 云端交互安全

传统安全架构下，边缘侧与云端主站通过专线，无线专网、或虚拟专用网络（Virtual Private Network, VPN）进行连接。与边缘网络类似，这种基于边界防控的做法使得接入设备一旦通过认证并被授权，就具备了网络的完全访问能力，接入云端主站后的行为就无法被管控；因此无论云端做了多么强大的边缘防护，一旦被渗透的边缘设备接入，就无法

抵御攻击者对云端服务的任何攻击。零信任总是验证、最小授权的理念将有效的避免这一问题。基于零信任的云端交互安全包括了可信接入网关、SDP 控制器以及边缘客户端（图 4）。云端交互安全与上节中边缘网络安全的实现理念是一致的，但呈现形式不同。此外，在边缘网络要兼顾更多的接入形式与协议；而云端交互安全则需要更多的考虑自身的鲁棒性与可靠性。

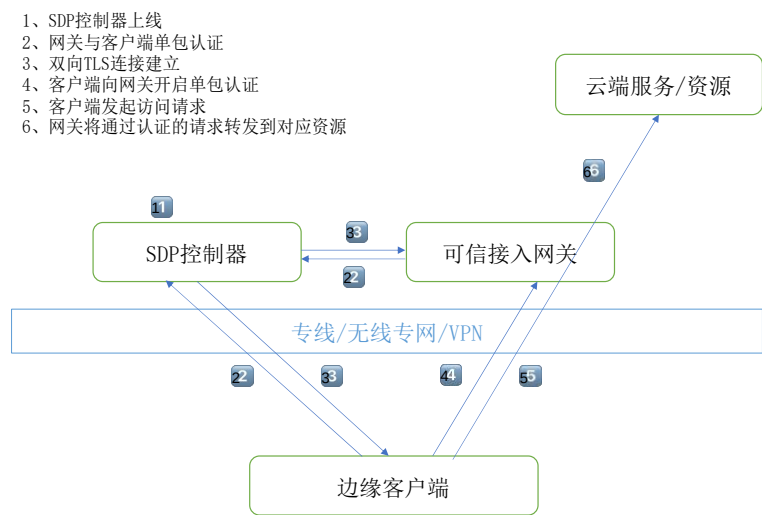


图 4. 云端安全交互

3.3.4. 安全持续监控与反馈

零信任要求对授权的访问请求持续监控。一旦发现异常，须要立即吊销对该访问的授权。在边缘安全区域自治，云边协同管理安全的架构下，边缘计算节点、边缘网络安全网关和云端交互安全网关的所有安全事件统一上报云端。云端综合威胁情报和其它云端安全及网络设备的事件信息集中分析，并计算下发对应的安全策略，实现整体系统的安全闭环。安全持续监控需要具备威胁情报收集、安全日志收集、自动化的安全分析以及策略下发等主要能力（图 5）。

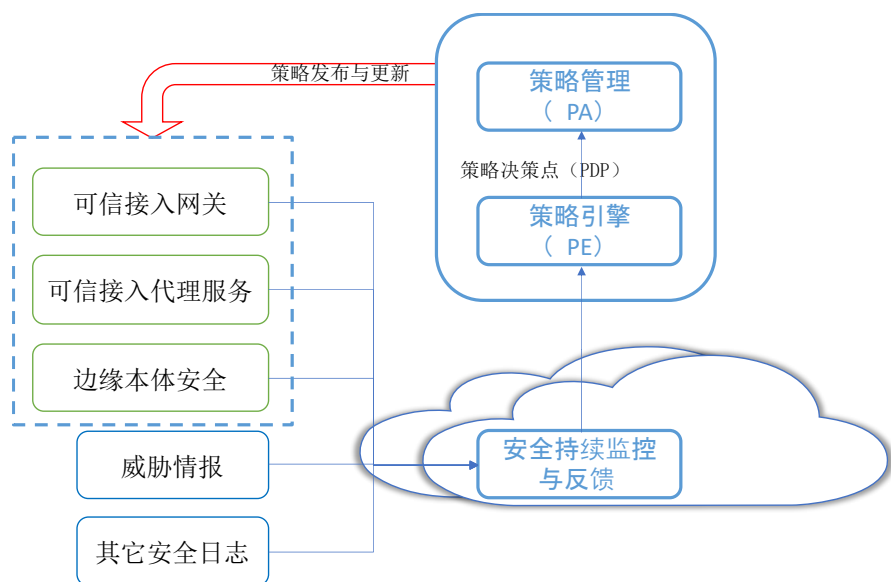


图 5. 安全持续监控与反馈

3.3.5. 本章小结

本章内容提出了边缘安全区域自治，云边协同管理安全的安全设计理念，并对其中的四个重要模块（边缘计算节点本体安全、边缘网络安全、云端交互安全及安全持续监控与反馈）需要具备的能力和研究重点进行了分析说明。

4. 研究思路与技术路线

4.1. 总体思路

本研究按照先个体再全局，先边缘再云端的计划进行。首先进行边缘节点本体安全的研究，包括嵌入式终端检测与响应（Endpoint Detection and Response, EDR），终端安全态势收集（Posture Collector）以及终端安全策略执行（Policy Enforcement Point, PEP）；接下来研究边缘网络安全和云端交互安全中的几个核心要素，包括 SDP 控制器，单包认证（Single Packet Authentication, SPA）技术，可信接入网关（PEP 在网关的实现）以及安全策略决策（Policy Decision Point, PDP）；最后通过对安全持续监控与反馈的研究，通过与 PDP 和 PEP 的联动完成云边协同的管控（图 6）。



图 6. 研究总体思路

4.2. 技术要点

4.2.1. 嵌入式终端检测与响应

EDR 技术在传统 PC 和服务器的应用较为广泛，但在嵌入式系统上的应用较少。本研究主要从技术对嵌入式系统的适配、系统运行时信息的收集及分析能力和资源消耗优化三个方面进行。

4.2.2. 终端安全态势收集

终端安全态势收集的主要目的是为了配合后续边缘网络及云端交互使用。边缘计算节点的安全态势信息将通过 SPA 包送到 SDP 控制器和可信接入网关，作为访问许可的关键依据。

4.2.3. 终端安全策略执行

作为云边协同的关键一环，PEP 在边缘计算节点上会随时执行云端发布的安全策略，包括但不限于，中断连接、终止进程、强制注销已登录用户、禁用用户账号等。

4.2.4. SDP 控制器

作为软件定义边界的关键要素，SDP 控制器在边缘网络安全和云端交互安全中都有至关重要的作用。SDP 控制器在边缘网络安全和云端交互安全中的呈现形式不尽相同，但是都需要具备几项关键能力：鉴别访问请求账户，与合法的客户端建立双向 TLS 认证（Mutual TLS authentication），并根据请求者的属性、受访资源的属性以及各种环境信息下发认证因子，供访问请求者后续通过可信接入网关访问资源。

4.2.5. 单包认证 (Single Packet Authentication, SPA) 技术

SPA 技术源于早期的 Port Knocking。它是零信任实现中“先认证后连接”的保证[5]。在 SPA 包中，需要包含尽可能充分的访问者和受访者的属性信息，以便可信接入网关能够对访问者授予适当的“最小权限”。SPA 包有一定的时效性，设计时要充分考虑遭遇重放攻击等入侵的可能性。

4.2.6. 可信接入网关

可信接入网关是 PEP 在边缘网络安全和云端交互安全的实现。其执行云端发布的安全策略的主要方式是允许或者拒绝访问者的访问请求。一旦允许，则需要将访问者的请求转发到真实的资源或服务提供者。可信接入网关是访问请求的关键节点，除了基本功能实现，自身的鲁棒性与可靠性也须细致研究。

4.2.7. 安全策略决策

PDP 是安全策略的制定者。根据当前的安全态势、资源属性、环境信息等数据，PDP 将计算出不同安全主体的安全策略，并交予 PEP 执行。安全持续监控与反馈是 PDP 的一项重要重要的信息源。

4.2.8. 安全持续监控与反馈

安全持续监控与反馈是系统中重要的安全事件收集者和分析者。首先，安全持续监控与反馈要为系统中各个安全主体提供安全事件上报的通道；然后根据包括威胁情报，和其它网络设备、云端安全设备等关键设备产生的事件日志在内的各种信息进行安全形势判断，并将结果输出给相对应的 PDP 进行策略的制定，实现整体系统的安全闭环。

4.3. 本章小结

本章简述了本研究的整体思路，并根据研究的八项重要技术点，对研究目标进行了介绍。

5. 预期效果

本研究预期能形成一套以边缘计算节点为中心的边缘安全区域自治的设计方法。完成对本研究的四个重点模块：边缘计算节点本体安全、边缘网络安全、云端交互安全及安全持续监控与反馈的工程化实现。基于本研究，预计发表核心期刊论文两篇（名称待定），申报专利两项《一种实现多类型多协议的可信安全接入方法及装置》（拟定名）、《一种基于容器的系统运行检测方法》（拟定名）及软件著作权三项（名称待定）。

6. 其它需要说明的问题

本文重点探讨了边缘安全区域自治的四个关键模块的研究思路与方法，预期能够实现边缘安全区域自治的基础功能。完全实现边缘安全区域自治和云边协同的安全管理还依赖很多的技术，需要在工程实践中不断研究、应用与完善。

参考文献：

- [1] T / CEC 101.1-2016 能源互联网 第 1 部分总则[S].
- [2] 刘振亚. 全球能源互联网[M]. 中国电力出版社, 2015.
- [3] 邱意民. 电力监控系统安全防护规定[M]. 浙江人民出版社, 2014.
- [4] Rose S, Borchert O, Mitchell S, et al. Zero Trust Architecture[R]. National Institute of Standards and Technology, 2020.
- [5] Bilger B, Boehme A, Folres B, et al. SDP Specification 1.0[J]. 2014.